

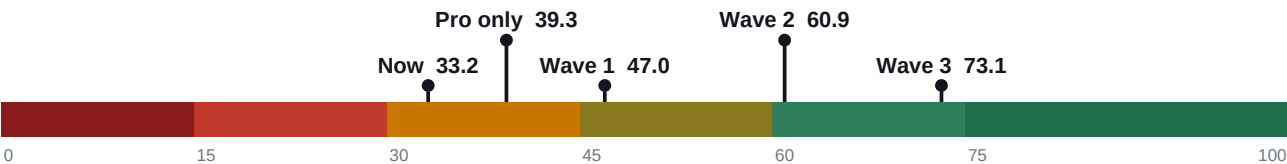
Raising the Score: What to Fix, and In What Order

Companion to the 14-metric assessment of incident 6bc323a620a6443f. Current stack: **Gemini 2.5 Flash / Flash-Lite**.

The short answer: your model is about 30% of the problem, and it is not where you should start.

Swap Flash and Flash-Lite for Gemini 2.5 Pro tomorrow, change *nothing else*, and the composite moves from **33.2** to **39.3**. Still FAILING. Meanwhile the first wave of deterministic plumbing -- validation tables, a shared state object, tool-call dedup -- involves **no model change at all** and moves you to **47.0**. The cheapest non-model work is worth more than twice the model upgrade. That ratio should decide your Q1.

PROJECTED TRAJECTORY



Wave 3 at **73.1** is upper SUPERVISED -- the honest ceiling for this product class today; see page 8 on why 85+ is not a credible target for anyone currently selling it.

SCENARIO	COMPOSITE	BAND	WHAT IT COSTS YOU
Today	33.2	FAILING	Current state: Flash / Flash-Lite, single model across all ten calls.
Model upgrade only	39.3	FAILING	Highest unit-cost increase of any option here, for the second-smallest gain.
Wave 1 -- guardrails	47.0	UNRELIABLE	Four to six weeks of engineering. No model change, no new integrations, no new spend.
Wave 2 -- evidence logic + routing	60.9	SUPERVISED	Eight to twelve weeks. Selective Pro routing on two of ten calls.
Wave 3 -- calibration + coverage	73.1	SUPERVISED	Three to six months. Labelled corpus, IdP integration, response policy.

01 What the model is, and is not, responsible for

Sixteen defects were logged in the assessment. Sorting them by what would actually have prevented them is the whole planning exercise, because the three classes have wildly different fix costs and only one of them is about Gemini.

CLASS	DEFECTS	WHAT WOULD HAVE PREVENTED IT	SHARE
A -- Model capability	Shallow hypothesis set; uncalibrated 80/20; one-hop recursion; narrow default windows	A stronger reasoning model, or ensemble sampling on the verdict step. Genuinely model-bound.	~30%
B -- Missing determinism	D-01 fabricated MITRE ID; D-02 corrupted ARN; D-09 duplicate call; D-13 RFC 5737 address	A lookup table and a hash check. No model, of any size, should ever have been asked these questions.	~25%
C -- Architecture and policy	D-03 four-way contradiction; D-04 template-as-finding; D-05/06 no remediation; D-07/08/10/11/12/14/15	A shared state object, a coverage manifest, a required-questions checklist, an action policy matrix. Frontier models fail these identically if the scaffolding is absent.	~45%

Class B is the one that should sting.

A quarter of your defects come from asking a language model to reproduce facts that live in a table. T1685.002 does not exist because a model invented it; it would not exist if the model had been made to *select* from the 600-odd valid ATT&CK IDs instead of typing one. The account ID lost a digit because the model retyped a 12-digit string; it would not have if the string had never entered the generation path. These are not AI problems. They are missing-lookup-table problems, and they are the ones ending your evaluations.

THE UNCOMFORTABLE COROLLARY

Because 70% of the defects are Class B and C, a model upgrade on its own makes the product *more* dangerous, not less. Gemini 2.5 Pro writes more fluent, more confident, better-structured prose around exactly the same unvalidated facts, the same contradictory state, and the same missing remediation. You would be raising the quality of the narrative while leaving the quality of the evidence untouched -- which is precisely the 2.04x framework-to-substance ratio the assessment identified, made worse. Fix the facts first. The reasoning upgrade compounds properly only once it has something true to reason over.

02 Where Flash and Flash-Lite specifically hurt you

Class A is real, and the fingerprints are visible in the report. Five named failure modes, each with the evidence that identifies it, and each with a fix that is cheaper than a blanket upgrade.

FAILURE MODE	FINGERPRINT IN YOUR REPORT	CHEAPEST FIX
Long-string infidelity. Small models transpose and drop digits when regenerating identifiers from context.	210087654321 for 210987654321 -- one digit, in the evidence string of the supported hypothesis.	Reference tokens. The model never sees or writes the real ARN.
Round-number pseudo-calibration. Fast-tier models emit confidence as narrative punctuation, not as a posterior.	80 / 20, summing to exactly 1.0, across a hypothesis pair that is not exhaustive. Real posteriors are not that tidy.	Take the number away from the model. Compute it in code.
Enumeration drift. Free-text identifiers get pattern-matched to plausible-looking strings.	T1685.002 has correct ATT&CK <i>shape</i> and no existence. T1087.004 in the same document is valid.	Constrained decoding against an enum. Zero model cost.
Shallow planning horizon. The model issues the obvious query and stops rather than widening or recursing.	within_seconds_of_anchor:1800 on every search; recursion halts after one hop; the recommended IP is never enriched.	Move planning into code. The agent follows a checklist, not its instincts.
Narrative lock-in. Once a direction is stated, later sections reinforce rather than re-examine it.	Page 1 asserts a connected chain; page 3 quietly admits corroboration was weak. Neither revises the other.	Generate sections from one state object, not sequentially.

Flash-Lite in a Tier 3 reasoning path is a category error.

Flash-Lite is an extraction and classification model. It is an excellent choice for parsing tool output, building tool arguments, and normalising records -- roughly six of your ten calls. It is the wrong instrument for generating competing hypotheses and assigning calibrated confidence to them, which is the entire job of a Tier 3 tier. Do not remove it. Stop asking it to do the two things it cannot do.

AND ONE ARCHITECTURAL TELL: 73 SECONDS

Ten tool calls in 73 seconds is roughly seven seconds per call including inference. That is a latency budget, and it is almost certainly *why* you chose Flash, why the windows are 1800 seconds, and why recursion stops at one hop. **Latency is the wrong optimisation target for Tier 3.** Tier 1 triage should be fast because volume is the constraint. A Tier 3 investigation that takes eight minutes and is right is worth vastly more than one that takes 73 seconds and is confidently wrong. If a single latency budget spans both tiers, that one decision is upstream of four of your fourteen metric scores.

03 Model routing: stop using one tier for ten jobs

The choice is not Flash versus Pro. It is which of your ten calls deserve which tier. Two of them carry almost all the reasoning value; the other eight are plumbing where Flash-Lite is genuinely the better engineering choice.

PIPELINE STEP	TODAY	SHOULD BE	WHY
Alert parsing, entity extraction	Flash	Flash-Lite	Structured extraction. Cheapest tier is correct and faster.
Tool argument construction	Flash	Code, not a model	Deterministic. A model choosing 1800 seconds is a bug, not a decision.
Tool output normalisation	Flash	Flash-Lite	Parsing JSON into records. No reasoning required.
Qualifier resolution	Flash	Flash	Bounded judgement over retrieved records. Flash is adequate.
Hypothesis generation	Flash	Pro	Breadth is the whole product here. Flash gives you two hypotheses; you need five.
Verdict and confidence	Flash	Pro + self-consistency	The one number a human acts on. Sample three times; disagreement is your calibration signal.
False-positive checks	Flash	Flash	Checklist evaluation against retrieved evidence. Adequate.
Detection suggestions	Flash	Pro (batched, async)	Off the critical path. Quality matters, latency does not.
Narrative rendering	Flash	Flash-Lite or templates	Rendering a state object. Should barely be a model call.
MITRE mapping, remediation	Flash	Lookup table	Never a model call. This is where T1685.002 came from.

Two calls upgraded, not ten.

Routing Pro to hypothesis generation and verdict only captures most of the reasoning benefit at a fraction of an all-Pro bill, because those two calls are also among your shortest. Two further steps leave the model entirely -- tool arguments and MITRE mapping become code -- which *reduces* spend while removing two defect classes. Verify current per-token pricing before you model this; the ratios between tiers move, but the shape of the argument does not: **pay for reasoning, never for lookup.**

WHAT TO MEASURE BEFORE COMMITTING

- Run the same 50 incidents through Flash-only and through the routed configuration. Compare hypothesis *count* and hypothesis *diversity*, not narrative quality -- narrative quality will improve either way and tells you nothing.
- Measure how often the compromised-credential-versus-insider distinction is drawn at all. In the sample incident it was never raised, and it is the branch that determines the response path. That single check is a good proxy for whether the reasoning tier is doing real work.
- Track verdict disagreement across three samples at temperature. High disagreement on an incident is not noise; it is the most honest uncertainty signal you can get cheaply from a model that cannot self-calibrate.

04 The core fix: three-valued evidence logic

One change addresses the structural defect identified on page 6 of the assessment -- confidence rising as investigation narrows. It is the highest-value item on this roadmap and the only one that changes what the product *is* rather than how well it does what it already does.

TODAY: THREE DIFFERENT SITUATIONS COLLAPSE INTO ONE ANSWER

SITUATION	WHAT THE SYSTEM RECORDS NOW	WHAT IT SHOULD RECORD	EFFECT ON CONFIDENCE
Source queried, coverage verified, genuinely no match	"No evidence found"	CONFIRMED_ABSENT	Legitimate disconfirming evidence. May move confidence.
Source queried but empty, unavailable, or not integrated	"No evidence found"	NO_COVERAGE	Must not move confidence in either direction.
Never asked at all	"No evidence found"	NOT_QUERIED	Must block conclusion, or force an explicit waiver.

In the sample incident, all three of H2's disconfirming items and three of four false-positive checks were null results treated as the first category. At least two were almost certainly the second -- a demo-tenant context store with no change tickets in it is NO_COVERAGE, not proof of unauthorised activity. Qualifier q2 was the third category: never queried, and silently dropped from the conclusion.

Warn your team now: this will make your confidence numbers go down, and that is the point.

Expect verdicts to fall from 80% to somewhere in the 55-65% range on incidents like this one. Internally that will read as a regression, and there will be pressure to tune it back up. Resist it. **The 80% was never real** -- it was manufactured by the narrowness of the search. The lower number is the first honest output the system will have produced, and it is the only foundation on which a calibration programme can be built. A product that says 60% and is right 60% of the time is worth more than one that says 80% and is right 60% of the time, and every serious buyer will eventually measure exactly that.

TWO SUPPORTING CHANGES

- **Adaptive search windows.** Derive the window from technique semantics rather than a constant. For T1562.008, infrastructure-as-code reconciliation runs on hourly-to-daily cycles, so a 30-minute lookforward for CreateTrail is close to guaranteed to return nothing. Escalate: query 30m, then 6h, then 24h -- and record which window produced the null, because that provenance is what makes the absence interpretable.
- **Coverage manifest.** Before concluding, state which sensors were in scope and which were not. "No related activity found" is meaningless without "across sensors: cdr only, same asset only." Publishing that line in the report does two things at once: it makes the reasoning honest, and it makes the cross-platform gap visible to you as a product roadmap item rather than invisible as a silent null.

05 Fix inventory

Twenty-two fixes. Type matters more than effort: eleven of them involve no model call at all.

ID	FIX	TYPE	EFF	MOVES
F-01	Validate technique IDs against a local ATT&CK; bundle; constrained enum, never free text	CODE	S	Data int., Det. eng.
F-02	Reference tokens for all identifiers; model never sees or retypes an ARN, IP, or hash	CODE	S	Evidence, Data int.
F-03	Tool-call dedup: hash normalised params, cache within an investigation	CODE	S	Evidence, cost
F-04	Reserved-range checks (RFC 1918 / 5737 / 3849, bogons) before recommending enrichment	CODE	S	Data integrity
F-05	Evidence provenance ledger: every narrative claim carries a record pointer or is blocked	ARCH	M	Evidence, Explain.
F-06	Single canonical state object; all sections render from it, never regenerate independently	ARCH	M	Correlation, Explain.
F-07	Qualifier state machine with explicit UNQUERIED / NO_DATA / NEGATIVE / POSITIVE states	ARCH	M	Investigation, Evidence
F-08	Render observed hops visually distinct from unevaluated correlation template legs	CODE	S	Correlation
F-09	Three-valued evidence logic; NO_COVERAGE and NOT_QUERIED cannot move confidence	ARCH	L	Calibration, Reasoning
F-10	Adaptive, technique-derived search windows with escalation and provenance	CODE	M	Investigation, Correlation
F-11	Coverage manifest published in every report	ARCH	S	Cross-plat., Explain.
F-12	Mandatory-question checklist per technique; cannot close with unanswered items	ARCH	M	Investigation, Evidence
F-13	Tiered model routing per pipeline step (see page 4)	MODEL	M	Reasoning, Hypothesis
F-14	Remove Flash-Lite from hypothesis and verdict paths; retain for extraction	MODEL	S	Reasoning, Hypothesis
F-15	Structured output with enums for every classification the model emits	MODEL	S	Data int., Evidence
F-16	Self-consistency sampling on the verdict step only; disagreement routes to human	MODEL	M	Calibration
F-17	Model emits structured evidence assessments; posterior computed in code	ARCH	L	Calibration
F-18	Calibration harness: labelled corpus, Brier score, published reliability curves	POLICY	L	Calibration, Prod.
F-19	Technique base rates as hypothesis priors	POLICY	M	Calibration, Reasoning
F-20	Technique-to-remediation lookup table, rendered mandatorily above threshold	CODE	S	Response
F-21	Confidence x severity action policy matrix; coverage gaps become tickets, not sentences	POLICY	M	Response, Prod.
F-22	Identity-provider integration for all federated principals	INTEG	L	Cross-platform

Effort: S = days, M = weeks, L = months. Type: **CODE** deterministic, no model | **ARCH** orchestration | **MODEL** inference change | **POLICY** process | **INTEG** new data source.

06 Roadmap and projected scores

Three waves. Wave 1 is entirely Class B and C work and needs no model decision, which is why it should start first and can start now. Projections are deliberately conservative; no metric is credited above 80.

METRIC	NOW		W1	W2	W3		PRINCIPAL FIXES
Reasoning	42		48	62	70		F-09, F-13, F-19
Investigation	31		40	60	70		F-07, F-10, F-12
Correlation	27		45	58	66		F-06, F-08, F-10
Hypothesis management	38		42	62	72		F-13, F-14, F-19
False-positive analysis	60		64	72	78		F-09, F-11
Explainability	52		68	74	80		F-05, F-06, F-11
Detection engineering	36		48	56	64		F-01, F-13
Recursive investigation	48		52	66	74		F-12, F-13
Evidence quality	26		55	66	74		F-02, F-03, F-05
Confidence calibration	28		34	52	74		F-16, F-17, F-18
Cross-platform investigation	18		22	34	66		F-11, F-22
Response automation	12		18	40	74		F-20, F-21
Data integrity	23		62	72	80		F-01, F-02, F-04, F-15
Production readiness	33		46	60	72		F-18, F-21
WEIGHTED COMPOSITE	33.2		47.0	60.9	73.1		

WAVE	CONTENTS	WINDOW	GATE TO EXIT
W1 Guardrails	F-01 to F-04, F-06, F-08, F-11, F-15, F-20. No model change required.	4-6 weeks	Zero invalid identifiers and zero cross-section contradictions across 100 replayed incidents.
W2 Evidence logic	F-05, F-07, F-09, F-10, F-12, F-13, F-14, F-16, F-21.	8-12 weeks	Every null result carries a coverage state. Verdicts drop and stay dropped.
W3 Calibration	F-17, F-18, F-19, F-22.	3-6 months	Published reliability curve on 200+ labelled incidents. Brier score beats the base rate.

07 What I would not promise, and what to do on Monday

BRUTAL NOTES

- **85+ is not a credible target, for you or for anyone currently selling this.** Wave 3 lands around 73 -- upper SUPERVISED, meaning an analyst still verifies before acting. Fully autonomous Tier 3 closure requires calibration nobody in this category has demonstrated publicly. Target the honest ceiling and say so in your marketing; the buyers who matter will trust you more for it, and the ones who do not will churn when they measure you anyway.
- **Do not ship the word "autonomous" until F-18 exists.** Claiming Tier 3 autonomous closure on an uncalibrated 80% is a liability rather than a feature. Position as Tier 1/2 triage assist with mandatory analyst confirmation. That is genuinely valuable, genuinely defensible, and genuinely what you have.
- **Audit the Lessons Learned feedback path before anything else on this list.** If those entries feed future investigations, prompts, or detection content, you are currently propagating "absence of benign activity indicates malice" into your own system. It is the only defect that compounds with time and volume. If that path exists, it is a same-week fix, not a Wave 1 fix.
- **No amount of prompting will fix calibration.** Every team tries "be well-calibrated, output a probability" first. It produces round narrative numbers -- your 80/20 is the fingerprint. Calibration requires taking the number away from the model, a labelled corpus, and measurement. There is no prompt-shaped shortcut, and the months you spend looking for one are the months a competitor spends building the corpus.
- **Your demo tenant is hiding the problem.** An empty context store returns null for every check, which under current logic pushes every verdict toward malicious. Your demo environment is systematically flattering your product, and it will stop doing so on the first real customer estate with populated change tickets. Build the replay corpus from real, messy, populated data before you tune anything.

THE FIRST THIRTY DAYS

WEEK	ACTION	WHY THIS ORDER
0	Audit whether Lessons Learned feeds anything downstream. Cut the loop if it does.	The only compounding defect. Everything else is static.
1	Ship F-01 and F-02: ATT&CK enum validation and identifier reference tokens.	Removes both findings that end an evaluation in the first two minutes. Days of work.
2	Ship F-03, F-04, F-08, F-20. Build the 100-incident replay harness.	Cheap deterministic wins, and you cannot measure any later change without the harness.
3	Ship F-06: single state object. Re-render all sections from it.	Kills the contradiction class outright and unblocks most of Wave 2.
4	Prototype F-13 routing on hypothesis and verdict only. Measure hypothesis count and diversity.	Now the model question is answerable with your data instead of with vendor benchmarks.

The one-sentence version.

Your model is a real constraint on roughly a third of the problem, and Flash-Lite genuinely does not belong in the reasoning path -- but three quarters of what is costing you the score is scaffolding a frontier model would not fix either, and the first six weeks of that work is worth more than double the entire model upgrade. **Build the guardrails, then buy the reasoning.**

Projections here assume the fixes land as described and are measured against a replay corpus you do not yet have; treat the numbers as direction and magnitude, not as forecast. They are derived from the same weighting model and the same single incident as the assessment, with all the sample-size limits that implies.